

## Guía Metodológica de la Encuesta CRA

Versión: 1.0

Objeto: describir el diseño, la lógica y el uso analítico de la Encuesta Integral sobre Preparación y Métricas CRA.

### 1. Objetivos de la encuesta

La encuesta persigue tres objetivos simultáneos y declaradamente ambiciosos:

1. Medir el grado de preparación de las organizaciones respecto al CRA, tanto en conciencia como en capacidad operativa.
2. Recoger datos estructurados para alimentar indicadores y un Índice Global de Madurez (IGM) alineado con las familias de métricas sugeridas por el CRA y la literatura contemporánea sobre ciberresiliencia.
3. Proporcionar a las organizaciones un espejo razonablemente fiel —no siempre halagador— de su situación, que ayude a priorizar decisiones de inversión, gobierno y desarrollo de capacidades.

### 2. Población, muestra y alcance

La población objetivo son organizaciones que diseñan, fabrican, integran, distribuyen o utilizan de forma intensiva productos con elementos digitales que puedan estar afectados por el CRA, con especial énfasis en aquellas con presencia en la UE.

La muestra puede definirse:

- Por sector (por ejemplo, industria manufacturera, servicios digitales, operadores críticos, administración pública).
- Por tamaño (micro, pequeñas, medianas, grandes).
- Por rol en la cadena de valor (fabricantes, desarrolladores, integradores, distribuidores, usuarios finales intensivos).

Idealmente, el respondente debería ocupar una posición directiva o tener visibilidad transversal sobre seguridad, producto y cumplimiento. En ausencia de la persona “perfecta”, es preferible recibir la perspectiva honesta de quien está en primera línea, aunque sea parcial.

### 3. Estructura del cuestionario

El cuestionario se organiza en once secciones, que responden a la lógica de indicadores identificada en el informe CRA previo:

4. Perfil de la organización
5. Conocimiento y gobernanza del CRA
6. Alcance de productos y conformidad
7. Desarrollo seguro, SBOM y ciclo de vida
8. Gestión de vulnerabilidades y parches
9. Incidentes, notificación y resiliencia operativa
10. Métricas, KPIs y reporting interno
11. Capacidades, formación y cultura
12. Impacto económico, IGM y ROI
13. Perspectivas, retos y apoyo necesario
14. Comentarios finales cualitativos

Cada bloque está diseñado para mapearse de forma relativamente directa a dimensiones de madurez y a requisitos normativos, lo que facilita tanto el cálculo de índices como el análisis comparativo entre organizaciones, sectores y países.

#### 4. Tipo de preguntas y escalas de respuesta

La encuesta combina:

- Preguntas de selección única (tipo “radiografía”), que simplifican el cálculo de indicadores.
- Preguntas de selección múltiple (retos, apoyos), que capturan la complejidad de la realidad.
- Preguntas abiertas, reservadas para matices y confesiones que no caben en casillas discretas.

Las escalas utilizadas son mixtas: categóricas ordinales (por ejemplo, “básico/intermedio/avanzado”) y rangos numéricos aproximados (por ejemplo, tramos de presupuesto). Esto reduce la carga cognitiva y protege cierta confidencialidad, a costa de una resolución algo menor, asumible a efectos de análisis.

#### 5. Cálculo del Índice Global de Madurez (IGM)

##### 5.1 Dimensiones del IGM

El IGM propone una puntuación compuesta de 0 a 100 para cada organización, agregando cinco dimensiones principales:

15. Gobernanza y estrategia (GOV)
16. Cobertura de productos y cumplimiento (COV)
17. Gestión de vulnerabilidades e incidentes (VULN)
18. Métricas y datos (DATA)
19. Capacidades y cultura (CAP)

Cada dimensión se calcula a partir de subconjuntos de preguntas, asignando puntuaciones numéricas a las categorías de respuesta.

##### 5.2 Ponderaciones sugeridas

A modo de propuesta inicial:

- GOV: 20 %
- COV: 20 %
- VULN: 25 %
- DATA: 15 %
- CAP: 20 %

Estas ponderaciones pueden ajustarse según sector o apetito regulatorio. Lo razonable es testar la estabilidad del índice con análisis de sensibilidad antes de sacarlo en una rueda de prensa.

### 5.3 Ejemplo de mapeo simplificado

- P5, P6, P7, P8 – GOV
- P9, P10, P11, P12 – COV
- P17, P18, P19, P20, P21, P22, P23, P24 – VULN
- P25, P26, P27 – DATA
- P28, P29, P30, P31, P32 – CAP

Cada respuesta se codifica (por ejemplo, de 0 a 3), se normaliza a 0–100 y se promedian las puntuaciones dentro de cada dimensión. Después se aplica la ponderación global para obtener el IGM.

## 6. Estimación de ROI (retorno de la inversión) CRA

### 6.1 Lógica básica

La sección 9 del cuestionario recoge información que permite estimar, de manera necesariamente aproximada:

- El esfuerzo inversor (porcentaje de presupuesto en ciberseguridad y cumplimiento, y dentro de este, parte atribuible al CRA).
- El impacto económico de incidentes que podrían haberse evitado o mitigado con mejores prácticas alineadas con CRA.

Con estos datos, se pueden construir indicadores de:

- Coste estimado de adaptación al CRA (en términos de inversión incremental).
- Pérdida evitada potencial (basada en incidentes previos y escenarios de reducción de probabilidad o impacto).
- Ratio “pérdida evitada / coste de adaptación”, como proxy de ROI.

### 6.2 Limitaciones

La honestidad obliga: el ROI en ciberresiliencia nunca será tan limpio como el de un proyecto de fábrica nueva. Los incidentes no ocurridos son, por definición, difíciles de contabilizar. Por eso se sugieren rangos de magnitud y no cifras exactas, y se recomienda complementar el análisis cuantitativo con juicio experto.

## 7. Administración de la encuesta

### 7.1 Canal y anonimato

La encuesta puede administrarse:

- En formato digital (preferible), con lógica de salto y validación básica.
- En entrevistas semiestructuradas, utilizando el cuestionario como guion.

En proyectos sectoriales o nacionales, se recomienda ofrecer la opción de respuesta anónima y la firma de acuerdos de confidencialidad para datos identificables, especialmente cuando se recaben cifras de impacto económico.

### 7.2 Duración

El tiempo estimado de cumplimentación, para alguien que conozca razonablemente la casa, es de 20–30 minutos. Menos si el respondente se ha estudiado el CRA con fervor; más si va descubriéndolo pregunta a pregunta.

## 8. Análisis de resultados

### 8.1 Niveles de madurez

Es posible categorizar las organizaciones en niveles de madurez CRA en función del IGM:

- 0–24: Exploradores (o “todavía en fase de negación”).
- 25–49: Reactivos.
- 50–74: Proactivos.
- 75–100: Estratégicos.

Estas etiquetas son intencionadamente coloquiales; pueden adaptarse a un lenguaje más sobrio si el foro lo exige.

### 8.2 Comparativas y benchmarks

Con un número suficiente de respuestas, se pueden generar:

- Perfiles sectoriales (por ejemplo, grado de preparación en fabricantes frente a usuarios finales).
- Comparativas por tamaño de organización.
- Mapas de calor por dimensión (GOV, COV, VULN, DATA, CAP).

En entornos nacionales, estos resultados son especialmente útiles para orientar políticas públicas, programas de apoyo y prioridades de supervisión.

## 9. Uso ético y comunicación

### 9.1 Transparencia con los participantes

Antes de administrar la encuesta, se recomienda informar claramente a las organizaciones sobre:

- El propósito de la recogida de datos.
- El uso previsto (informes agregados, benchmarks, etc.).
- Las medidas de anonimización y protección de datos.

## 9.2 Comunicación de resultados

Al presentar los resultados, conviene:

- Evitar rankings simplistas de “los buenos” y “los malos”.
- Enfatizar tendencias, brechas y oportunidades de mejora.
- Ofrecer recomendaciones prácticas y recursos de apoyo.

## 10. Actualización y mantenimiento

El CRA, sus estándares asociados y la práctica industrial evolucionarán. La encuesta y esta guía metodológica deberían revisarse:

- Cada vez que haya cambios significativos en la regulación o en las guías técnicas relevantes.
- Cada 2–3 años como mínimo, para incorporar lecciones aprendidas y nuevas métricas de ciberresiliencia.

Mientras tanto, es perfectamente legítimo seguir preguntando, midiendo y afinando, que es la manera civilizada de convivir con la incertidumbre.